

Access Control

- Enforce strong password policies and deploy Microsoft Entra Password Protection.
- Enforce Multi-Factor Authentication (MFA) for all users, applications, and client types; remove unnecessary exclusions.
- Implement Privileged Access Management (PAM) and rotate privileged/service account credentials regularly.
- Disable legacy authentication protocols (e.g., ROPC, unsupported methods).
- Restrict device-code authentication, allowing only approved emergency accounts.
- Limit Azure CLI access to authorized administrators.
- Adopt phishing-resistant authentication (FIDO2, Windows Hello for Business, certificate-based methods).

Data and Resource Protection

- Secure SharePoint and OneDrive with least privilege access, restricted external sharing, and comprehensive audit logging.
- Strengthen Conditional Access policies based on trusted IPs, geolocation, compliant devices, and risk signals.
- Protect user sessions with Continuous Access Evaluation (CAE), session lifetime controls, and device compliance requirements.
- Implement Data Loss Prevention (DLP) policies across Microsoft 365 services to detect anomalous data access and exfiltration.
- Audit and remove suspicious mailbox rules that redirect, delete, or suppress notifications.

Governance and Preparedness

- Review Microsoft 365 security configurations (Conditional Access, OAuth permissions, sharing settings, audit coverage).
- Strengthen incident response preparedness with defined procedures and periodic tabletop exercises.
- Conduct security awareness training for users on credential theft, phishing, BEC, suspicious attachments, and safe authentication practices.

Conclusion

CERT-In advises all organizations using Microsoft 365 to treat any suspected account compromise as a potential security incident requiring immediate investigation and response. Early detection of anomalous authentication activity, phishing attempts, unauthorized device registrations, suspicious OAuth usage, and unusual access to Microsoft 365 services is critical to preventing unauthorized access, data exfiltration, Business Email Compromise (BEC), and other malicious activities.

Organizations are advised to review and strengthen Microsoft Entra Conditional Access policies, enforce Multi-Factor Authentication (MFA) for all users and applications, disable or restrict legacy and device-code authentication where operationally feasible, implement robust monitoring and audit logging, and regularly review privileged access, mailbox rules, and device registrations.

If any indicators of compromise or suspicious activity associated with these attack techniques are detected, organizations should immediately initiate incident response procedures, preserve all relevant logs and forensic evidence, implement appropriate containment measures, and report the incident, along with all relevant artifacts and logs, to CERT-In at incident@cert-in.org.in.

References

<https://www.ic3.gov/PSA/2026/PSA260521>
<https://www.huntress.com/blog/lshiy-password-spray-attack>
<https://www.bleepingcomputer.com/news/security/hackers-target-microsoft-365-accounts-with-81-million-login-attempts/>

Disclaimer

The information provided herein is on "as is" basis, without warranty of any kind.

Contact Information

Email: info@cert-in.org.in
Phone: +91-11-22902657

Postal address

Indian Computer Emergency Response Team (CERT-In)
Ministry of Electronics and Information Technology
Government of India
Electronics Niketan
6, CGO Complex, Lodhi Road,
New Delhi - 110 003
India

Indian Computer Emergency Response Team - CERT-In, Ministry of Electronics and Information Technology, Government of India.

[Website Policies](#) | [Terms of Use](#) | [Help](#)

Last Updated On September 22,
2026